

Module 13

Authenticate and authorize user identities on GitHub



Agenda



GitHub Foundations Part 1

- 1 Introduction to Git
- 2 Introduction to GitHub
- 3 Introduction to GitHub's products
- 4 Configure code scanning on GitHub
- 5 Introduction to GitHub Copilot
- 6 Code with GitHub Codespaces
- 7 Manage your work with GitHub Projects
- 8 Communicate effectively on GitHub using Markdown

GitHub Foundations Part 2

- 9 Contribute to an open-source project on GitHub
- 10 Manage an InnerSource program by using GitHub
- 11 Maintain a secure repository by using GitHub best practices
- 12 Introduction to GitHub administration
- 13 Authenticate and authorize user identities on GitHub
- 14 Manage repository changes by using pull requests on GitHub
- 15 Search and organize repository history by using GitHub
- 16 Using GitHub Copilot with Python

Introduction

GitHub Enterprise provides robust authentication and authorization options to ensure secure access to company data, allowing administrators to enforce security policies, audit user activity, and maintain compliance.

By the end of this module, you'll be able to:

- Identify the identity providers and technologies that support secure repository access.
- Understand the implications of enabling SAML SSO.
- Identify the authorization and authentication options available, and understand the administrator's role in enforcing a secure access strategy for a GitHub enterprise.
- Describe how users access private information in a GitHub organization.
- Evaluate the benefits of enabling Team Synchronization to manage team membership.

SCIM

User identity and access management



Organization Management through SAML SSO

- SAML SSO: Links IdP authorization with access to service providers, allowing single sign-on for all applications.
- Administrator Responsibilities: Authorize user access, perform routine audits, and maintain tightly scoped access.



Access Management with Multiple Organizations

- Group Management: Use organizations to create distinct user groups within a company, such as divisions or project teams.
- Repository Access: Public and internal repositories are accessible to members of other organizations, while private repositories are restricted.



Organization Private Information

- Repository Visibility: Members can create public, private, or internal repositories, with access controlled based on repository type.
- Access Control: Certain organization members have access to internal repositories, ensuring secure collaboration.

User authentication (SAML SSO)

Enforce SAML SSO

- **Enforcement** : After enabling SAML SSO, enforce authentication to make it mandatory for all organization members.
- **Steps to Enforce**: Go to Your organizations > Settings > Organization security, and select "Require SAML SSO authentication for all members."



Test SAML configuration

Before enabling test your SAML SSO configuration

- ☐ **Require SAML SSO authentication for all members of the Hubot Holdings USA organization.**
Requiring SAML SSO will remove all members (excluding outside collaborators) who have not authenticated their accounts. Members will receive an email notifying them about the change. Leaving this option unchecked will allow you to test before requiring.

Save

User authentication (Multifactor authentication)



- **Two-Factor Authentication (2FA):** Requires a secondary form of authentication in addition to the username and password.
- **Implementation:** members, outside collaborators, and billing managers must enable 2FA on their accounts, and administrators should communicate this requirement to the team.

Two-factor authentication

Requiring an additional authentication method adds another level of security for your organization.

- ☒ **Require two-factor authentication for everyone in the octo-org organization.**
Members and outside collaborators who do not have two-factor authentication enabled for their personal account will be removed from the organization and will receive an email notifying them about the change.

Save

User authentication (SAML SSO through SCIM)



- **SAML SSO** secures access to GitHub resources, while SCIM automates user identity management, including provisioning and deprovisioning.
- **SCIM** ensures automatic removal of user access when sessions expire, preventing unauthorized access even after session expiration.

SCIM User Provisioning

☒ **Require SCIM user provisioning**

Enabling SCIM provisioning will disable SAML Just-In-Time provisioning of users. All users must be provisioned via SCIM.

Save

User authentication (SSH key and PAT)

- User lifecycle-management changes in your IdP are automatically reflected in GitHub, with SAML and SCIM ensuring synchronized identities and group memberships.
- Users need to authorize with a PAT or SSH key for API and Git access, and administrators can review these authorizations.



Octokey
SHA256:p+AD5XWsK2aiEPwWEC/6zWh77v8inMs1JT+rW5IR3/g
Added on Jul 3, 2018
Last used within the last 24 hours

SSH

Enable SSO ▾ Delete

Check out our guide to [generating SSH keys](#)

Single sign-on organizations
These organizations require keys to be authorized for access. [See the documentation](#) for more information.

 octo-org [Authorize](#)

SSH Certificate Authorities

Team synchronization

- Automatically reflects changes made in IdP groups on GitHub, reducing manual updates and custom scripts.
- Allows for efficient onboarding, permission management, and access revocation.
- Requires enabling SAML SSO and SCIM by the IdP Administrator.

Features	Description
Sync Users	Add or remove users from <code>Teams</code> in GitHub to keep in sync with Active Directory groups
Sync on new team	Synchronize users when a new team is created
Custom team/group maps	The team <code>slug</code> and group name will be matched automatically, unless you define a custom mapping with <code>syncmap.yml</code>
Dynamic Config	Utilize a <code>settings</code> file to derive Active Directory and GitHub settings

Team synchronization (cont.)

Team synchronization is also available for organizations and enterprise accounts that use GitHub Enterprise Cloud.

Enterprise Managed Users

- **Provisioning and Management:** All members are managed through your IdP, with no self-created accounts on GitHub.
- **Restrictions:** Managed user accounts are restricted to their enterprise and cannot interact outside of it.

Usage Limits

- **Team and Organization Limits:** Maximum of 5,000 members per team, 10,000 members per organization, and 1,500 teams per organization.
- **Performance Impact:** Exceeding these limits can lead to performance issues and synchronization failures.

Enabling Team Synchronization

- **Administrative Tasks:** Use IdP to manage onboarding, permissions, and member access, with changes reflected automatically on GitHub.
- **Supported IdPs:** Only available with Microsoft Entra ID and Okta, requiring administrative access to configure.

Prerequisites and Configuration

- **IdP Integration:** Obtain administrative access or work with your IdP administrator to configure integration and groups.
- **Connecting Teams:** Team maintainers and organization owners can connect teams to IdP groups on GitHub or through the API.

Summary

In this module, you learned about allowing access to your users, and how the authentication systems available for your GitHub organization help keep your sensitive data secure.

You learned about:

- How SAML SSO and 2FA are more secure than username/password authentication.
- Which identity providers are supported by GitHub.
- How user authorization with SCIM is supported by GitHub.
- What options users have to identify with two-factor authentication.
- How team synchronization through your IdP can automate team membership and help keep access to your data secure..